LOMBA KOMPETENSI SISWA (LKS) KOTA MALANG 2026

DAY 3 – BLUE TEAM

SMKN 4 MALANG

Written by:

- **Zacharia Esen**
- **Ramadhan Arga Adiansyah**

Table of Contents

FORENSCIS 5

VERIFIED 5

ANALYZE 5

SOLVE 6

FLAG: LKS{bob_n} 6

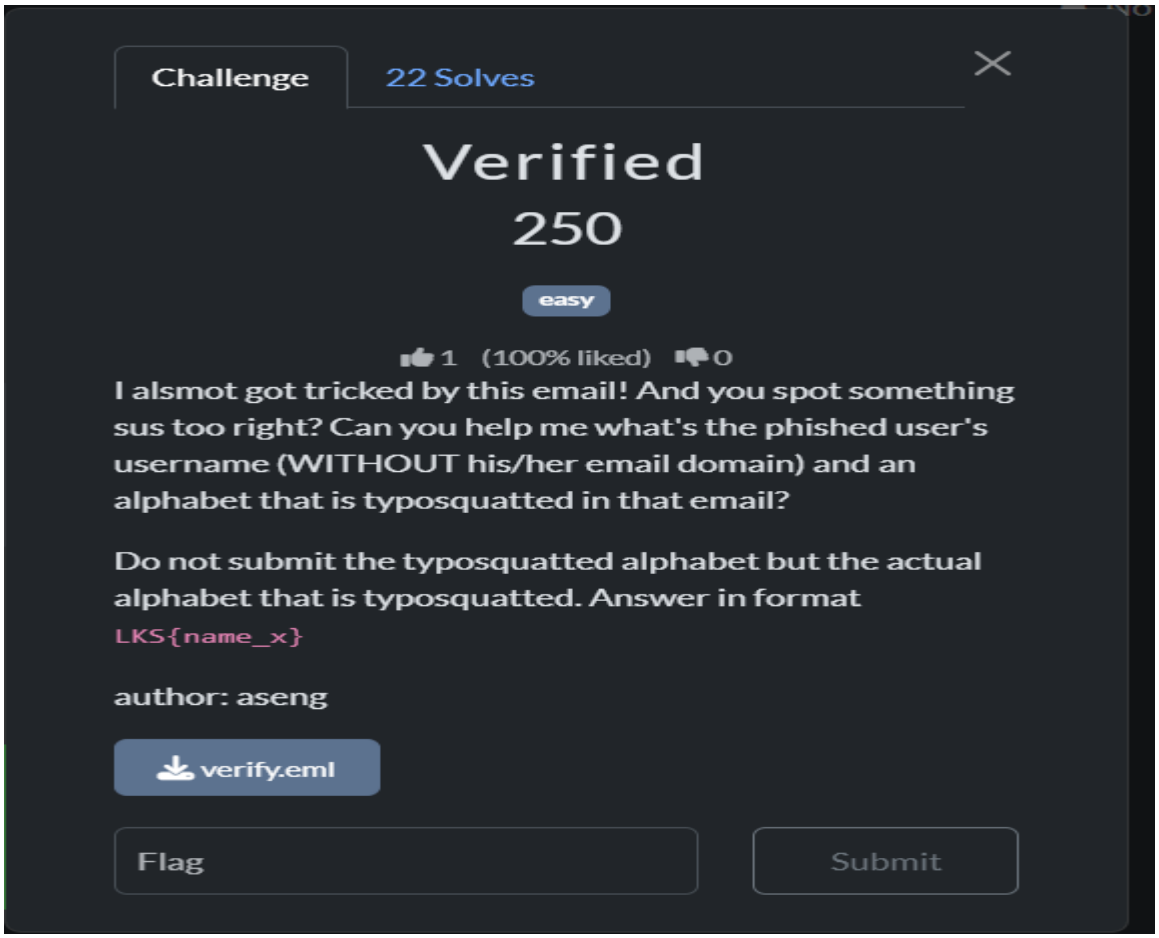
FoodJection 7

ANALYZE 7

SOLVE 8

FLAG: LKS{Xf!ltr4tr10n_SQLi_asique} 10

VERIFIED



ANALYZE

Diberikan file verivy.eml yang berisi percakapan email dari zeno.vemtom.idhello ke <bob@recipient.idhello>. Pada isi eml tersebut terlihat kalau attacker menyamar sebagai orang dari "Roman Bank Security Team" yang memberi tahu victim bahwa terdapat login yang tidak biasa di akunnya, lalu attacker mengarahkannya ke url "http://roman-bank-verify.idhello/login?id=bo"

SOLVE

Untuk solve soal ini, ditugaskan untuk mencari nama victim dan typosquatted yang ada di url. Jadi attacker

menggunakan typosquatted ke URL yang diberikan ke victim untuk membuat seolah olah url yang diberikan adalah url yang valid, padahal url tersebut merupakan url phising attacker.

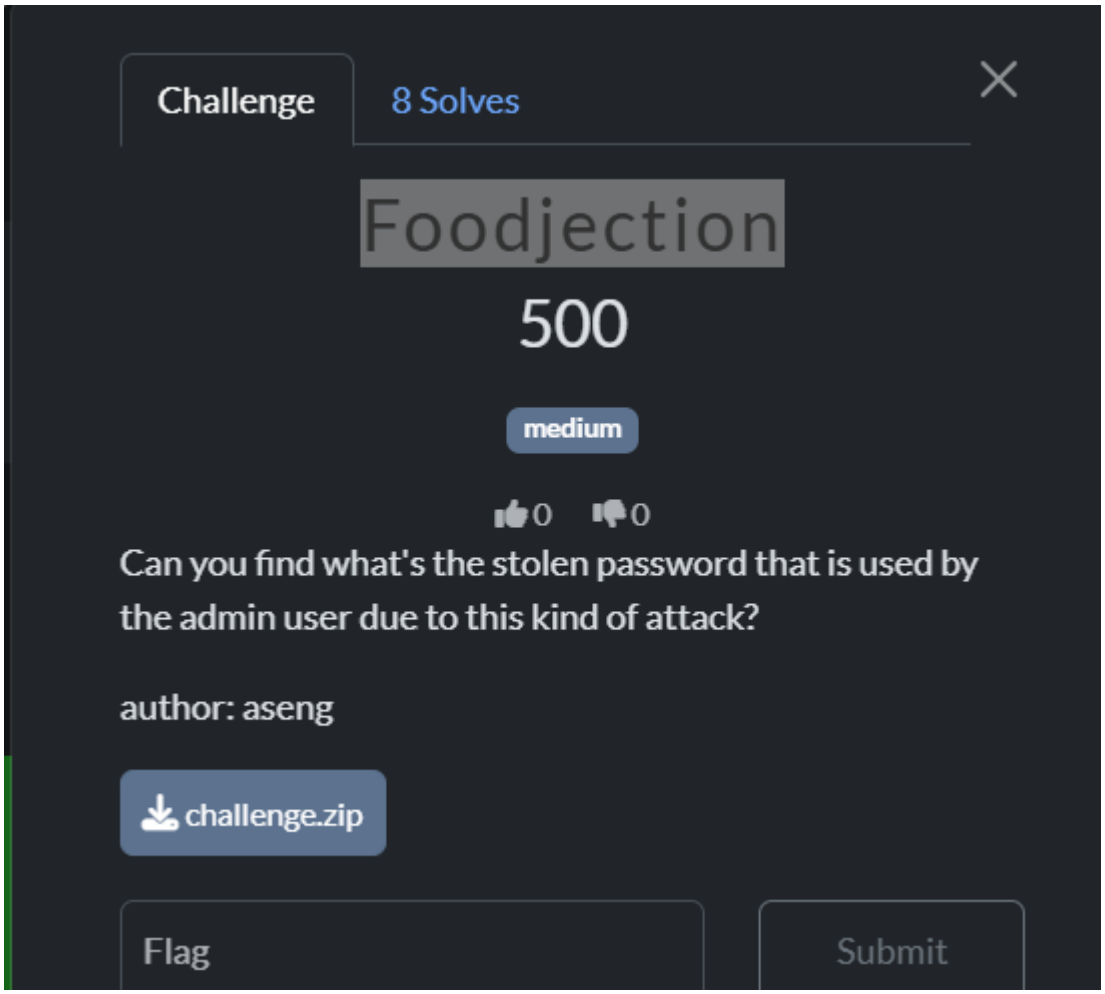
Kalau dilihat baik baik, terlihat ada keanehan apda huruf "n" di url yang diberikan.

```
a href="http://roman-bank-verify.idhello/login?id=bob">
```

Ukuran huruf "n" lebih kecil dibanding alfabet lain.
Jadi bisa disimpulkan kalau typposquattednya adalah "n".

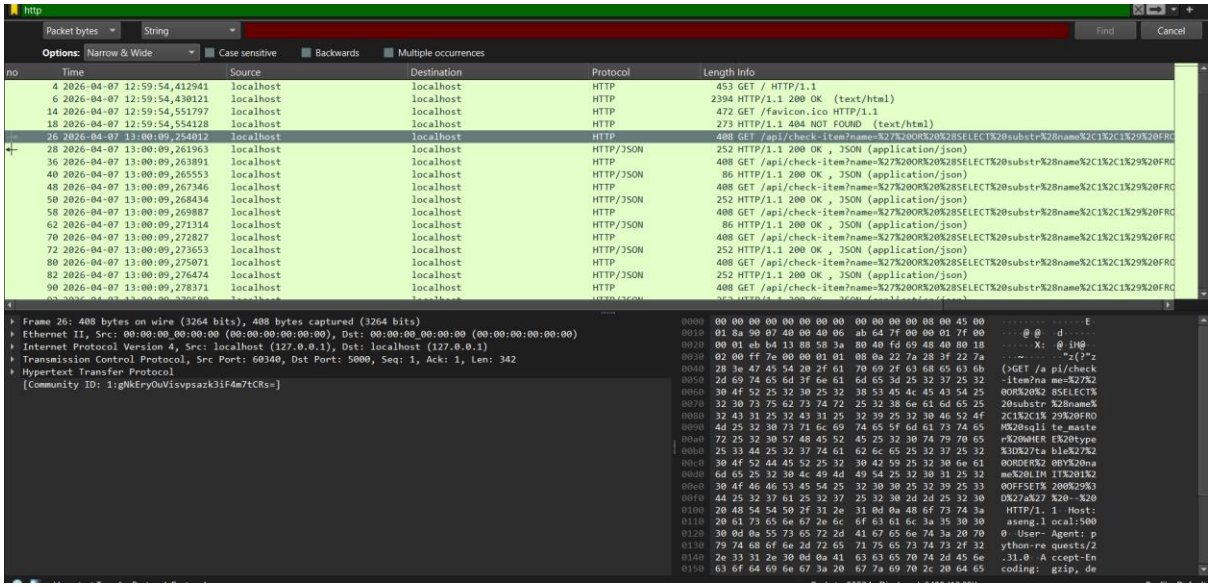
FLAG: LKS{bob_n}

FoodJection

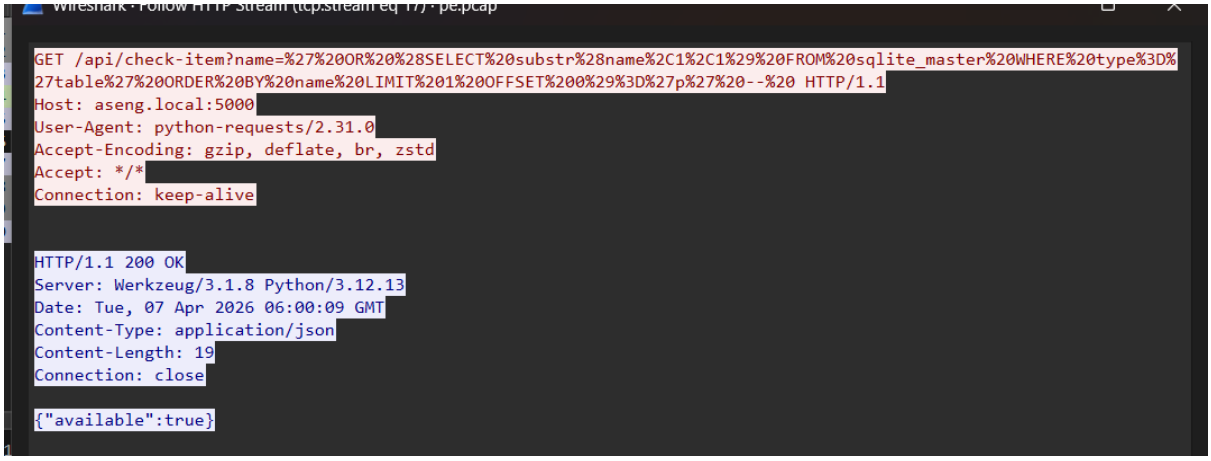


ANALYZE

Diberikan file pcap yang didominasi oleh protocol http. Dan terdapat aktivitas mencurigakan yang terekam pada protocol http, yaitu adanya inject payload SQL



Disitu terlihat attacker menggunakan teknik boolean sqli. Jadi attacker akan menebak karakter-karakter yang ada di database secara satu per satu, jika karakter yang ditebak benar, server akan mengembalikan true, jika salah berarti false.



SOLVE

Tujuan kita adalah menemukan password yang telah berhasil di tebak oleh attacker. Langsung saja filter packet yang mengandung "pass"

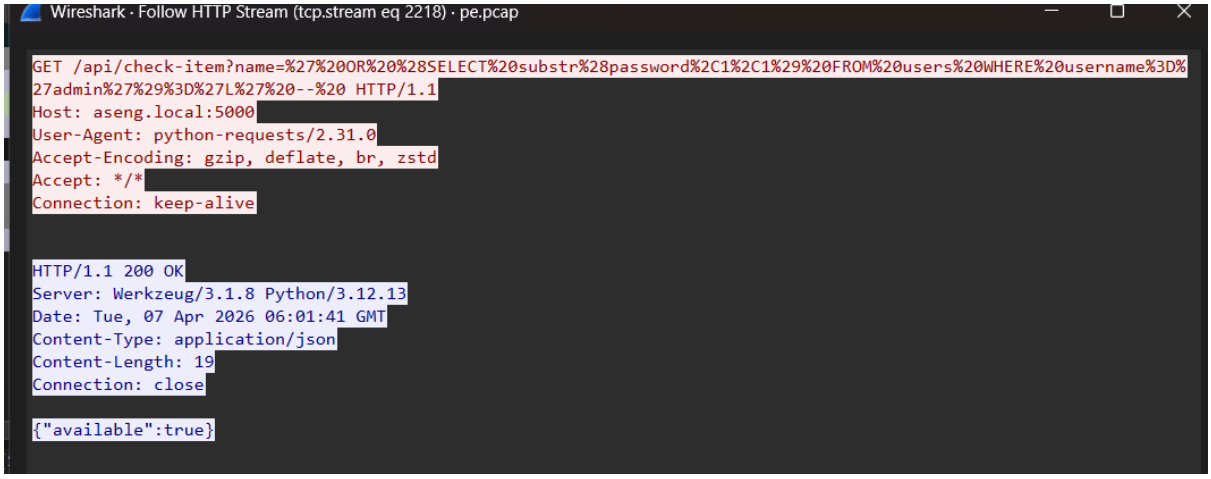
Attacker menggunakan payload seperti ini

```
' OR (SELECT substr(password,1,1) FROM users WHERE
username='admin')='a' --
```

Jadi payload ini menggunakan OR yang menghubungkan query original ke payload attacker. Jika part ini true, seluruh query menjadi true.

Lalu menggunakan "(SELECT substr(password,1,1) FROM users WHERE username=admin)" yang merupakan sub query. Attacker menggunakan ini untuk melihat table user dengan username admin, lalu mengekstrak karakter pertama dari password (1,1) Setelah itu attacker mengcompares karakter ”a” ke server.

Bagaimana kita menebak passwordnya? Yaitu dengan mengamati respon true/false dari server. Jadi kita akan melihat packet dengan respon true.



Contohnya seperti ini, jadi attackere menebak karakter “L”, dan server mengembalikan true, yang artinya karakter tebakan tersebut benar. Langsung saja kita ekstrak satu-satu karakternya dengan hanya mengekstrak karakter yang membuat server mengembalikan true.

Dan kami mendapatkan password: LKS{Xf!ltr4tr10n_SQLi_asique}

FLAG: LKS{Xf!ltr4tr10n_SQLi_asique}

NOTE: SPLUNK DAN WAZUH SAYA ERROR, JADI TIDAK BISA MENGERJAKAN SOC huhu...